

An Empirical Study of MCP Server Security: 6 Attack Surfaces from

Shiqiang Chen — July 15, 2026

Abstract

The Model Context Protocol (MCP) enables AI agents to interact with external tools through a standardized interface. As

1. Introduction

The Model Context Protocol (MCP), introduced by Anthropic in 2024, standardizes how AI agents interact with external too

Security research on MCP remains nascent. Trail of Bits (2025) documented MCP-specific attacks including ANSI injection

We address this gap by auditing 30+ MCP servers and categorizing all discovered vulnerabilities into 6 attack surfaces.

2. Methodology

2.1 Server Selection

We searched GitHub for repositories with topic:mcp-server across Python (63 results), TypeScript (89), Go (22), and Rust

2.2 Audit Process

Each server underwent a 4-phase audit:

1. Automated Scan: Semgrep with 40 custom rules across 7 languages
2. Manual Code Review: Focused on tool parameter handling, authentication, and transport security
3. Exploit Verification: Docker-based local emulation for confirmed vulnerabilities
4. Report Generation: Standardized security reports with CWE classification

2.3 Tools

We developed mcp-scan, an open-source MCP security scanner implementing our 6 attack surface checks, and released it at

3. Results

3.1 Vulnerability Rate

3.2 Attack Surface Distribution

3.3 Original Vulnerabilities Discovered

CVE #1 — cherrystudio-qq-mcp CWE-22

- Tool: qq_upload_file(file_path) → open(file_path) without validate_safe_path()
- Impact: Unauthenticated arbitrary file read
- CVSS: 7.5

CVE #2 — cherrystudio-qq-mcp CWE-918

- Tool: recognize_image(url) → requests.get(url) without URL validation
- Impact: SSRF, internal network scanning

- CVSS: 6.5

4. The 6 Attack Surfaces

AS1: Tool Parameter Injection

MCP tools accept parameters from AI clients. When `file_path`, URL, or SQL parameters lack validation, injection occurs. A

AS2: Inspector Exposure

MCP debugging tools bind to 0.0.0.0 without authentication in default configurations. Affected: 3 servers (9%). Examples

AS3: Client Trust Exploitation

MCP servers fully control tool descriptions visible to AI clients. A malicious server can disguise dangerous tools or ph

AS4: Transport Security

8 servers (23%) use plain HTTP without TLS for MCP communication. Additional issues include lack of message signing and

AS5: Implementation Flaws

Standard web vulnerabilities in MCP context: hardcoded secrets, SQL injection, `eval()` without sandbox. Affected: 1 serve

AS6: Supply Chain

MCP servers distributed as npm/pip packages. 15 servers (43%) had no security advisory policy or security contact listed

5. Discussion

5.1 Why the Vulnerability Rate is Low

The MCP ecosystem's 4% vulnerability rate is significantly lower than typical web applications (estimated 60-80% [OWASP,

- MCP's stdio-default transport (local-only)
- Smaller, well-defined tool interfaces
- Early adopter profile (more security-conscious developers)

5.2 Why Vulnerabilities Are Severe When They Occur

When MCP vulnerabilities exist, they are typically severe because MCP tools have:

- Direct filesystem access (read/write arbitrary files)
- Network access (SSRF)
- Process execution (shell commands)
- No authentication by default

5.3 Recommendations

1. For MCP tool developers: Implement `validate_safe_path()` before every file operation
2. For MCP protocol designers: Consider mandatory transport security in the specification
3. For AI platform operators: Audit third-party MCP servers before deployment
4. For the research community: Extend this taxonomy to the growing MCP ecosystem

6. Conclusion

We presented the first empirical study of MCP server security, identifying 6 attack surfaces from 30+ audits. Our key fi

Tools & Data

- mcp-scan: github.com/ShiqiangChen/mcp-scan
- awesome-mcp-security: github.com/ShiqiangChen/awesome-mcp-security
- Audit data: available in the publications/ directory

References

- [1] Trail of Bits. "MCP Security Series." 2025.
- [2] Invariant Labs. "MCP Security Notification: Tool Poisoning Attacks." 2025.
- [3] Shiqiang Chen. "Prompt Injection is Not an AI Problem." 2026.
- [4] OWASP Foundation. "OWASP Top 10." 2023.
- [5] CVE-2025-49596. MCP Inspector Remote Code Execution.
- [6] CVE-2026-23744. MCPJam Inspector Remote Code Execution.